

REPORTE EJECUTIVO DE RIESGOS

Clinica privada - Direccion

Fecha: 10/09/2026 Responsable: Responsable de Seguridad

Resumen ejecutivo

La clinica atiende aproximadamente 800 pacientes diarios y depende de sistemas digitales para historias clinicas, obras sociales y facturacion. El registro inicial identifica ocho riesgos. Cinco requieren tratamiento prioritario por su posible impacto sobre la continuidad asistencial, la confidencialidad y el cumplimiento.

Top 5 riesgos

R01 - Ransomware sobre EHR y servidores: 20, CRITICO. EDR, segmentacion, backups inmutables y recuperacion probada.

R05 - Phishing y robo de credenciales: 16, CRITICO. MFA, filtros, capacitacion y reporte de incidentes.

R04 - Indisponibilidad de red o servidor: 15, ALTO. Redundancia, UPS, monitoreo y contingencia.

R02 - Acceso indebido a historias clinicas: 12, ALTO. RBAC, MFA, recertificacion y monitoreo.

R06 - Backups incompletos o no recuperables: 10, ALTO. Regla 3-2-1 y pruebas de restauracion.

Planes de accion

PA-01 - Recuperacion confiable ante ransomware. Mitigacion: Mitigate. Responsable: Infraestructura. Estado: En progreso (25%). Vencimiento: 15/10/2026. Esfuerzo: Medio/Alto. Presupuesto: ARS 3.500.000.

PA-02 - Identidad segura y minimo privilegio. Mitigacion: Mitigate. Responsable: Seguridad. Estado: Pendiente (0%). Vencimiento: 30/10/2026. Esfuerzo: Medio. Presupuesto: ARS 900.000.

PA-03 - Continuidad de servicios clinicos. Mitigacion: Mitigate. Responsable: Infraestructura y Mantenimiento. Estado: Pendiente (0%). Vencimiento: 15/11/2026. Esfuerzo: Medio. Presupuesto: ARS 2.000.000.

Recomendaciones prioritarias

1. Aprobar PA-01 y validar una restauracion real; mantener una copia offline o inmutable y ejecutar simulacros semestrales.
2. Activar MFA, depurar roles y realizar recertificacion trimestral de cuentas y privilegios.
3. Mantener manuales de contingencia, probar UPS y revisar bimestralmente baterias y fuentes de poder.
4. Medir MFA habilitado, exito de backups, tiempo de recuperacion, avance de mitigaciones y riesgos vencidos.

Documento basado en el registro de riesgos de la clinica. No contiene credenciales ni datos clinicos.